

# ISO/IEC 27001:2022 Gap Assessment

Maple Financial Services — Simulated Portfolio Assessment

## Executive Summary

This simulated assessment evaluates selected ISO/IEC 27001:2022 ISMS requirements and representative Annex A controls for a fictional financial-services organization. It demonstrates GRC capabilities including gap analysis, control assessment, risk prioritization, Statement of Applicability thinking and remediation planning.

**Important:** This is a portfolio exercise, not a certification audit. The organization, evidence, findings and recommendations are fictional and do not claim ISO/IEC 27001 conformity or certification.

## Key Findings

| Priority | Finding                                                  | Management Focus                                                                                |
|----------|----------------------------------------------------------|-------------------------------------------------------------------------------------------------|
| Critical | Identity lifecycle and access-control gaps               | Strengthen joiner/mover/leaver controls, approvals, deprovisioning evidence and access reviews. |
| Critical | Inconsistent risk assessment and treatment documentation | Formalize ISMS risk methodology, treatment plans and acceptance criteria.                       |
| High     | Vulnerability remediation governance gaps                | Establish severity-based SLAs and exception governance.                                         |
| High     | Supplier security controls vary by vendor                | Implement risk-tiered due diligence and contractual security requirements.                      |
| High     | Logging coverage and retention are inconsistent          | Define minimum logging standards and monitoring expectations.                                   |
| High     | Formal ISMS internal-audit program is not established    | Create an annual audit plan and finding follow-up process.                                      |

## Remediation Roadmap

| Timeframe   | Priority Actions                                                                          |
|-------------|-------------------------------------------------------------------------------------------|
| 0–90 days   | Standardize identity lifecycle controls and formalize ISMS risk assessment and treatment. |
| 31–120 days | Implement vulnerability SLAs, strengthen supplier security and improve logging standards. |
| 61–120 days | Launch an ISMS internal-audit program and track continual-improvement actions.            |

## References

ISO/IEC 27001:2022 — Information security, cybersecurity and privacy protection — Information security management systems — Requirements. ISO/IEC 27001:2022/Amd 1:2024. ISO/IEC JTC 1/SC 27 — ISO/IEC 27000 family.